

מקורות אלה מציגים דיון מעמיק ומפורט אודות היבטים שונים של חוק ותקנות הגנת הפרטיות בישראל, תוך התמקדות בפרקטיקות אבטחת מידע. הדוברים עורכים סקירה רחבה של החובות הרגולטוריות החלות על ארגונים, כגון מינוי ממונים על אבטחת מידע, ניהול הרשאות גישה, עריכת סקרי סיכונים ודרישות בנוגע לנהלי אבטחה. חלק משמעותי מהדיון מוקדש לחלוקת האחריות בין בעל מאגר המידע למחזיק (כולל ספקי ענן), כמו גם לחובת הדיווח על אירועי אבטחה חמורים לרשות להגנת הפרטיות. לבסוף, המקורות מנתחים אירועי דליפת מידע בולטים (כגון אלקטור, פייבוקס ומד"א), כדי להדגים את השיקולים העסקיים והרגולטוריים המורכבים בקבלת החלטות בנוגע להשקעה באבטחת מידע.

סיכום מקיף של ההרצאה בנושאי הגנת הפרטיות ואבטחת מידע

ההרצאה עסקה בעקרונות המרכזיים של חוק יסוד: כבוד האדם וחירותו, חוק הגנת הפרטיות, ובעיקר בתקנות הגנת הפרטיות (אבטחת מידע) משנת 2018, תוך התמקדות ביישום המעשי, חובות בעלי התפקידים והשלכות של פסיקות משפטיות מרכזיות.

עקרונות יסוד וחקיקה

הזכות לפרטיות מעוגנת בחוק יסוד, ופועלת מכוח חוק הגנת הפרטיות המגדיר מונחי מפתח כגון "מידע אישי" ו"מאגר מידע". שני עקרונות יסוד החוזרים בחוק ובתקנות הם:

1. עיקרון צמידות המטרה: יש להגדיר את מטרת איסוף המידע ולהיצמד אליה.

2. עיקרון איסוף מידע מינימלי: יש לאסוף רק את המידע הנחוץ להשגת המטרה, ויש לוודא אחת לשנה כי לא נאסף מידע רב מהנדרש. שמירת מידע נחשבת אף היא כ"עיבוד מידע".

בעלי תפקידים ואחריותם

החוק מגדיר הבחנה בין בעל מאגר מידע (בעל השליטה במאגר, נושא באחריות העליונה) לבין המחזיק (נותן שירות, לרוב מי שמתפעל את המערכת).

הממונה על אבטחת מידע (CISO): חובה למנות ממונה על אבטחת מידע בארגונים המחזיקים מעל חמישה מאגרים החייבים ברישום, או גופים החייבים בהודעה (כגון גוף ציבורי, בנק, או גוף המחזיק מעל 100,000 רשומות מידע בעל רגישות מיוחדת). תפקידו המרכזי של הממונה כולל:

• הכנת נוהל אבטחת מידע: הבאתו לאישור בעל המאגר.

• הכנת תוכנית בקרה שוטפת: לוודא עמידה בדרישות התקנות.

• הקצאת משאבים: בעל המאגר מחויב חוקית להקצות לממונה משאבים הדרושים למילוי תפקידו.

• ניגוד עניינים (CISO מול DPO): קיימת מחלוקת אם יש ניגוד עניינים אינהרנטי בין תפקידי ה-CISO (הרוצה לאסוף מידע לבקרה) לבין ה-DPO (האמון על צמצום איסוף המידע). ההמלצה היא להפריד בין התפקידים ככל שהארגון גדול יותר והמידע רגיש יותר, אם כי אין קביעה רגולטורית חד-משמעית.

דרישות נוהל אבטחת מידע (לפי רמות האבטחה)

תקנות 2018 מחלקות את המאגרים לשלוש רמות אבטחה (בסיסית, בינונית, גבוהה) וקובעות את דרישות האבטחה בהתאם, כאשר נוהל האבטחה מהווה "תוכן עניינים" לדרישות אלה.

דגשים עיקריים בדרישות האבטחה (נוהל אבטחה):

מקורות	דגשים חשובים	דרישה מרכזית (בינונית/גבוהה)	תחום
	חיוני להבנת מבנה המאגרים והסיכונים.	מיפוי תשתיות, חומרה, תוכנה, קשרי רשת.	מיפוי ומערכות
	סקרי הסיכונים חייבים לכלול גם סיכוני פרטיות (כגון שימוש חורג או איסוף יתר).	חובה לבצע סקר סיכונים לפחות אחת ל-18 חודשים (ברמת אבטחה גבוהה).	סקר סיכונים
	יש לתת את הדעת גם על מחשבים עם גישות אדמין וחדרי שרתים.	מנגנון מניעת כניסה לא מורשית ותיעוד כניסה/יציאה (בינונית/גבוהה).	אבטחה פיזית
	הדרכות תקופתיות: חובה לערוך הדרכה תקופתית לפחות אחת לשנתיים (רמת בינונית/גבוהה). המלצת ה-Best Practice היא אחת לשנה.	הליך מיון עובדים המותאם לרגישות המידע אליו תהיה להם גישה.	ניהול כוח אדם
	נדרשת בקרה תקופתית לאורך חיי העובד (מעבר תפקיד, חל"ת, סיום העסקה) למניעת הרשאות עודפות (Access Creep).	ניהול רישום מעודכן של הרשאות התואמות את הגדרת התפקיד (עקרון ה-Least Privilege).	הרשאות גישה
	תיעוד אוטומטי של גישה למערכות חייב להישמר למשך 24 חודשים לפחות (רמת בינונית/גבוהה).	שיטות זיהוי חזקות (MFA, סיסמאות מורכבות, החלפה תדירה).	זיהוי ואימות
	שחזור גיבוי מחייב אישור של מנהל המאגר (פונקציה בכירה).	נוהל גיבוי ושחזור של כל המידע והלוגים, עם עותק גיבוי נוסף (ברמה גבוהה) להבטחת שלמות המידע.	גיבוי ושחזור
	הגישה מרחוק למאגר מחייבת אמצעים לזיהוי המשתמש (כגון כרטיס חכם).	העברת מידע רק בשיטות הצפנה מקובלות, והטמעת אמצעי הגנה מפני חדירה.	אבטחת תקשורת

התקשרות עם ספקים ונותני שירות (תקנה 15)

תקנה 15 מסדירה את היחסים בין בעל השליטה במאגר לבין מחזיק המידע (נותן השירות/ספק ענן).

• **בדיקת נאותות (Due Diligence):** בעל המאגר חייב לבחון את הסיכונים הכרוכים בהתקשרות עם המחזיק ולבצע בדיקת אמינות.

• **הסכם כתוב:** ההסכם חייב להגדיר במפורש את מטרות הגישה, היקף עיבוד המידע (צמצום מידע), ואמצעי האבטחה שהספק מחויב ליישם בהתאם לרמת האבטחה של המאגר.

• **דיווח ובקרה:** המחזיק חייב לדווח לבעל המאגר אחת לשנה על עמידתו בחובות, ובעל המאגר מחויב לבצע בקרה ופיקוח על מידתו של המחזיק.

• **מודל אחריות משותפת (Cloud):** האחריות מתחלקת בין הארגון לספק הענן (כגון AWS או Azure) בהתאם למודל השירות (IaaS, PaaS, SaaS). הארגון חייב לוודא שהספק עומד בתקנים ובתהליכי העדכון הנדרשים (גם אם אין לו כוח לבדוק את מבנהו הפנימי של הספק).

אירועי אבטחה ודיווח לרשות

אירוע אבטחה מוגדר כמקרה בו יש חשש לפגיעה בשלמות המידע, שימוש שלא בהרשאה או חריגה מהרשאה, **כולל צפייה בלבד** במאגר.

• **דיווח מיידי:** בעל המאגר (או המחזיק, שצריך לדווח מיידית לבעל המאגר) חייב לדווח לרשות להגנת הפרטיות באופן **מיידי** (מיד) אם התרחש **אירוע אבטחה חמור**.

• **הגדרת "חמור":**

◦ רמת אבטחה בינונית: רק אם השימוש נעשה בחלק מהותי מהמאגר.

◦ רמת אבטחה גבוהה: כל שימוש בלתי מורשה במאגר נחשב חמור.

הרשות מבקשת דיווח מיידי גם כדי שתוכל לראות תמונה כללית יותר של דפוסי פעולה (חוכמת המונים) ולסייע לארגון ולארגונים דומים להתמגן.

תקנות העברת מידע והשוואת סטנדרטים (GDPR)

• **העברת מידע לחו"ל:** העברת מידע מחוץ לגבולות המדינה (לדוגמה, שימוש בשרתי ענן באירופה/ארה"ב) מותרת רק על בסיס חוקי מוגדר (כגון הסכם או העברה למדינה החתומה על האמנה האירופאית).

• **השוואת סטנדרטים (2023):** תקנות חדשות קבעו כי אם מאגר מידע מחזיק במידע על תושבי האיחוד האירופי וגם על תושבי ישראל, הסטנדרטים הגבוהים שנקבעו בתקנות אלה יחולו על **כל המידע** במאגר. דרישות אלה כוללות, בין היתר, זכות מחיקה (אלא אם קיימת הצדקה חוקית לשמירה, כגון ניהול הליך משפטי או גביית חובות).

פסיקה ויישום מעשי (פרטיות העובד)

פסיקות בית המשפט והנחיות הרשות מספקות איזון בין הצורך העסקי באבטחה לבין זכויות הפרטיות של העובדים.

1. ניטור תיבות דואר אלקטרוני (פס"ד טלי זקו):

° בית המשפט מחלק את התיבות לשלושה סוגים: מקצועית (מותר ניטור, בכפוף להודעה מראש, הסכמה מפורשת ועמידה בעקרונות תום לב ומידתיות); מעורבת (אסור ניטור); אישית (אסור ניטור, גם אם נכנס אליה מהתשתית של העבודה).

° ההמלצה הפרקטית היא לקבוע **מדיניות ברורה** וליישם **אמצעים טכנולוגיים** (כגון חסימת גישה לג'מייל פרטי) כדי למנוע יצירת "תיבה מעורבת". פתרון יעיל הוא שימוש בתיבות דואר כלליות (לפי תפקיד/לקוח) כדי לשמר את הרשומות הנדרשות להמשכיות עסקית.

2. מצלמות מעקב במקום העבודה:

- ° מותר להציב מצלמות למטרת **תכלית ראויה ולגיטימית** (כגון ביטחון עובדים או ציוד).
- ° **שקיפות:** אסור בתכלית האיסור לצלם בסתר, והעובדים חייבים להיות מודעים (שלטים, מדיניות ברורה).
- ° **מידתיות:** יש למקם את המצלמות כך שישלמו את האזורים הציבוריים, ולא באופן ממוקד על עמדת העבודה, המחשב או אזורים פרטיים (כגון שירותים).

3. שעוני נוכחות ביומטריים (פס"ד עיריית קלנסווה):

- ° **אסור** להשתמש בשעון נוכחות ביומטרי (ובכלל בטכנולוגיית זיהוי ביומטרית טהורה) **אלא אם כן יש הצדקה ממשית** והדבר הכרחי (כגון כניסה לחדרים נקיים או חדרי שרתים עם חומרים רגישים).
- ° כאשר יש צורך ביומטרי, יש להעדיף שיטות "ביומטריה לא טהורה" (שלא שומרות את המידע הביומטרי עצמו) ותמיד יש לספק לעובד **אלטרנטיבה** הולמת (כרטיס חכם, קוד אישי).
- סיכום והקשר עסקי

האחריות על קיום החוק חלה בסוף על ההנהלה הבכירה ועל הדירקטוריון. ישנם עיצומים כספיים גבוהים על הפרות (החל מ-20,000 ש"ח להפרות קלות במאגר בינוני, והכפלות לפי מספר נושאי המידע).

הדגש החשוב ביותר הוא כי עמידה בדרישות הרגולציה אינה רק מניעה מפני קנסות או תביעות, אלא משרתת יעדים עסקיים קריטיים: שמירה על **אמון הלקוחות** ועל **המוניטין** של הארגון. ארגונים (כגון בנקים) הפועלים בסקטור עם סיכון מוניטין גבוה, נדרשים להשקיע יותר משאבים באבטחה מאשר ארגונים אחרים, כיוון שהנזק העסקי מדליפה עולה על הנזק הרגולטורי.

כלי עזר להבנה, ניתן לחשוב על **חוק הגנת הפרטיות ותקנותיו** כעל **תוכנית הגנה מפורטת (נוהל אבטחה)**, ועל **הפסיקות המשפטיות** כעל "**מבחני מידתיות**" הבוחנים האם הכללים **יושמו באופן הוגן ומאוזן ביחס לאדם הפרטי**.